

Seguranca, resiliencia e operacao do homelab

Ambiente de producao do sistema Lembrado

Conclusao executiva: o ambiente esta operacionalmente estavel, mas apresenta lacunas relevantes de recuperacao e seguranca. A prioridade absoluta e estabelecer backup verificavel antes de qualquer atualizacao, fechamento de portas ou alteracao de infraestrutura.

ESCOPO

Servidor 192.168.1.11, containers Docker, rede, proxy, tunel, persistencia, atualizacoes, autenticacao administrativa e exposicao publica.

Campo	Informacao
Data da avaliacao	29 de julho de 2026
Metodo	Levantamento remoto somente leitura
Classificacao	Uso interno - contem informacoes de infraestrutura, sem credenciais
Responsavel pelo ambiente	Leandro / Lembrado

Nenhum segredo, token, chave de API, senha, chave SSH ou valor de variavel sensivel foi incluido neste documento.

1. Resumo executivo

A auditoria identificou um ambiente enxuto, funcional e com sinais positivos de estabilidade: todos os nove containers estavam ativos, sem reinicializações, o sistema respondia rapidamente, os endpoints sensíveis testados exigiam autenticação e os cabeçalhos públicos de segurança estavam presentes.

O risco principal não está em uma indisponibilidade atual, mas na combinação de ausência de backup restaurável, superfícies administrativas expostas na rede, componentes com privilégios equivalentes a root e um proxy reverso atrasado em relação a correções de segurança. Essas lacunas podem transformar uma falha operacional, credencial comprometida ou atualização mal-sucedida em perda prolongada do serviço.

Prioridade obrigatória: não atualizar containers, alterar firewall, excluir DNS, remover volumes ou fechar portas antes de criar backups fora do host e validar ao menos uma restauração em ambiente isolado.

1.1 Classificação geral

Dimensão	Avaliação	Leitura executiva
Disponibilidade atual	Boa	Containers estáveis e respostas HTTP rápidas.
Recuperação de desastre	Crítica	Não foi encontrada rotina de backup ou teste de restauração.
Superfície de ataque	Alta	Portas administrativas e da aplicação escutam em todas as interfaces.
Gestão de privilégios	Alta	Docker, Portainer e socket Docker ampliam o impacto de uma credencial comprometida.
Atualizações	Moderada/alta	Nginx Proxy Manager requer prioridade; demais componentes exigem janela planejada.
Observabilidade	Moderada	Logs existem, mas faltam healthchecks, limites e alertas estruturados.

1.2 Ordem recomendada

1. Backup completo e teste de restauração.
2. Confirmação da titularidade do IP antigo e limpeza de DNS, proxies e certificados obsoletos.
3. Atualização controlada do Nginx Proxy Manager.
4. Redução da exposição de portas e implantação de política de firewall.
5. Hardening do SSH e separação de privilégios administrativos.
6. Proteção e rotação planejada de segredos.
7. Healthchecks, limites de recursos, rotação de logs e monitoramento.

8. Atualizacoes restantes e plano de migracao do Debian.
9. Rotina continua de testes de restauracao e revisoes trimestrais.

2. Escopo, metodo e limitacoes

A avaliacao foi executada por acesso SSH autorizado ao host, com comandos somente leitura. Foram inspecionados sistema operacional, capacidade, processos, portas, containers, imagens, redes, volumes, configuracoes expostas pelo Docker, logs recentes, DNS publico, certificados e respostas HTTP.

2.1 Itens verificados

10. Inventario de hardware, sistema operacional, kernel, memoria, disco, swap, uptime e sincronizacao de horario.
11. Servicos escutando no host e portas publicadas por containers.
12. Versoes, usuarios efetivos, capacidades, perfis de seguranca, reinicializacoes e consumo dos containers.
13. Persistencia local, volumes Docker, configuracoes de stacks e existencia de rotinas de backup.
14. Logs das ultimas 24 horas, renovacao de certificados e estado do erro 502 anteriormente investigado.
15. Resolucao DNS, caminho do Cloudflare Tunnel, cabecalhos HTTP e protecao basica de endpoints internos.
16. Estado de atualizacoes do Debian e comparacao de componentes criticos com versoes publicadas.

2.2 Limitacoes

17. As regras efetivas de nftables e encaminhamentos do roteador nao foram confirmados porque a elevacao sudo exige senha interativa.
18. Nao foi realizado teste de restauracao, varredura ativa, exploracao, alteracao de configuracao ou reinicializacao.
19. A titularidade do endereco 2.57.91.92, ainda referenciado por dominios antigos, permanece pendente de confirmacao do responsavel.
20. Valores de segredos e credenciais nao foram coletados nem reproduzidos; somente os nomes das categorias de configuracao foram considerados.
21. Avaliacao pontual: o estado pode mudar apos atualizacoes, alteracoes de DNS, novos containers ou mudancas no roteador.

3. Arquitetura observada

Fluxo principal: Internet -> Cloudflare Tunnel -> cloudflared -> 192.168.1.11:80 -> Nginx Proxy Manager -> gestor_app:3000.

```
Internet
-> Cloudflare Tunnel
  -> cloudflared
    -> host 192.168.1.11:80
      -> Nginx Proxy Manager
        -> gestor_app:3000

Rede Docker gestor_gestor-network
gestor_app | gestor_worker | gestor_scheduler
evolution_api | evolution_db (PostgreSQL) | redis_queue | nginx-npm-1

Rede bridge
cloudflared | portainer
Portainer -> /var/run/docker.sock (leitura e escrita)
```

3.1 Dependencias de dados

- 22. Banco principal da aplicacao: Supabase externo.
- 23. Banco PostgreSQL local: dados da Evolution API.
- 24. Redis local: filas e estado operacional.
- 25. Volumes locais: sessoes da Evolution, dados do Nginx Proxy Manager, certificados e Portainer.

Ponto de falha: todos os dados locais persistentes identificados residem no mesmo disco fisico do host. A perda do equipamento ou do sistema de arquivos pode atingir simultaneamente dados e configuracoes.

4. Inventario tecnico

4.1 Host

Item	Estado observado
Hardware	Lenovo ideapad 320-14IKB; arquitetura x86-64; 4 CPUs logicas.
Sistema	Debian GNU/Linux 12 (bookworm), kernel 6.1.0-48-amd64.
Memoria	3,6 GiB totais; aproximadamente 2,0 GiB em uso; 1,6 GiB disponiveis.
Swap	975 MiB totais; aproximadamente 240 MiB em uso.
Armazenamento	167,7 GB; raiz ext4 com cerca de 17 GB usados e 138 GB livres (11%).
Operacao	Uptime aproximado de 62 dias e 23 horas; carga baixa; NTP sincronizado.

Item	Estado observado
Energia	Bateria informada como cheia, 100%.
Fuso horario	America/Sao_Paulo.

4.2 Containers e versoes

Componente	Imagem/versao	Estado
Aplicacao	ghcr.io/leoraujof/gestormaster:latest; commit f4d5fbd94db	Ativo; UID 1001
Worker	mesma imagem da aplicacao	Ativo; UID 1001
Scheduler	mesma imagem da aplicacao	Ativo; UID 1001
Evolution API	evoapicloud/evolution-api:v2.3.7	Ativo; root
PostgreSQL	postgres:15-alpine; 15.18	Ativo; UID 70
Redis	redis:7-alpine; 7.4.9	Ativo; UID 999
Cloudflared	latest; 2026.7.2	Ativo; patch 2026.7.3 sugerido
Nginx Proxy Manager	latest; 2.14.0	Ativo; root; atualizar
Portainer CE	latest; 2.39.2	Ativo; root

Todos os nove containers estavam ativos, com politica de reinicializacao configurada e zero reinicializacoes observadas.

4.3 Portas escutando no host

Porta	Servico	Exposicao observada
22	SSH	Todas as interfaces IPv4/IPv6
80/443	Nginx Proxy Manager	Todas as interfaces IPv4/IPv6
81	Administracao NPM	Todas as interfaces IPv4/IPv6
3000	gestor_app	Todas as interfaces IPv4/IPv6
8000/9443	Portainer	Todas as interfaces IPv4/IPv6
8080	Evolution API	Somente rede interna Docker
5432	PostgreSQL	Somente rede interna Docker
6379	Redis	Somente rede interna Docker

Nao foi encontrado UFW instalado. O pacote nftables existe, mas as regras efetivas nao foram auditadas sem elevacao sudo.

4.4 Volumes persistentes

- 26. gestor_evolution_db_data - banco PostgreSQL da Evolution.
- 27. gestor_evolution_instances - sessoes e instancias da Evolution.
- 28. gestor_redis_queue_data - dados persistentes do Redis.
- 29. nginx_npm_data e nginx_npm_letsencrypt - configuracoes, estado e certificados do proxy.
- 30. portainer_data - configuracao do Portainer e arquivos das stacks.
- 31. portainer_date - volume possivelmente incorreto ou sem uso; deve ser verificado antes de qualquer remocao.

5. Controles positivos encontrados

- 32. Todos os containers estavam em execucao e sem reinicializacoes observadas.
- 33. Aplicacao, worker e scheduler executam com usuario nao root (UID 1001).
- 34. Nenhum container foi identificado como privileged ou com cap-add explicito.
- 35. Perfis padrao de AppArmor e seccomp estavam ativos.
- 36. Evolution API e painel de filas rejeitaram acesso sem autenticacao.
- 37. O site publico respondeu com HSTS, CSP, protecao contra framing, nosniff, politica de permissoes e politica de referencia.
- 38. Cloudflare Tunnel reduz a necessidade de publicar diretamente o IP residencial para o dominio principal.
- 39. Pacotes Debian nao apresentavam atualizacoes pendentes no momento da coleta; timers diarios estavam funcionando.
- 40. Disco com ampla folga e carga do host baixa.
- 41. Nao foram encontrados novos registros de 'upstream sent too big header' apos o ajuste de buffers, indicando sucesso da correcao do 502.

Leitura correta: os controles existentes reduzem riscos, mas nao substituem backup restauravel, segmentacao administrativa, politica de firewall e gestao de privilegios.

6. Registro de achados

ID	Severidade	Achado	Tratamento
F-01	Alta	Ausencia de backup e restauracao	Imediata
F-02	Alta	Nginx Proxy Manager 2.14.0 atrasado em correcoes de seguranca	Apos backup

ID	Severidade	Achado	Tratamento
F-03	Alta	Portas administrativas e aplicacao expostas em todas as interfaces	Curto prazo
F-04	Alta	Portainer e grupo docker com privilegio equivalente a root	Curto prazo
F-05	Alta	Segredos de alto valor disponiveis a administradores Docker/Portainer	Curto prazo
F-06	Alta operacional	DNS antigo e renovacoes ACME falhando repetidamente	Apos confirmacao
F-07	Media/alta	SSH permite superficie maior que a necessaria	Curto prazo
F-08	Media	Sem healthchecks e limites de recursos	Medio prazo
F-09	Media	Logs Docker sem rotacao explicita	Medio prazo
F-10	Media	Redis com vm.overcommit_memory=0	Curto prazo
F-11	Media	Politica de atualizacoes e ciclo de vida do Debian	Planejado
F-12	Baixa	Exposicao de tecnologia e CSP permissiva	Oportunistica

6.1 F-01 - Ausencia de backup e restauracao

Severidade: Alta

Evidencia. Nao foram encontrados restic, borg, rclone, duplicity, rsnapshot, rsync, diretorios de backup, dumps SQL, crontab do usuario ou servico dedicado. Os unicos backups identificados sao rotinas de banco de pacotes do Debian, que nao protegem dados da aplicacao.

Impacto. Falha de disco, erro humano, corrupcao, atualizacao malsucedida ou comprometimento podem causar perda simultanea de banco local, sessoes, certificados, configuracoes do proxy e stacks.

Recomendacao. Implementar backup criptografado fora do host, retencao definida, monitoramento de sucesso e teste de restauracao isolado. Exportar tambem os arquivos Compose armazenados dentro do volume do Portainer.

6.2 F-02 - Nginx Proxy Manager atrasado

Severidade: Alta

Evidencia. O ambiente executa a versao 2.14.0. A versao 2.15.0 inclui OpenResty atualizado e correcoes associadas a vulnerabilidades publicadas.

Impacto. O proxy esta na fronteira de entrada HTTP/HTTPS. Uma vulnerabilidade nessa camada pode afetar confidencialidade, integridade e disponibilidade.

Recomendacao. Atualizar somente depois do backup e de um plano de rollback. Fixar uma versao explicita, validar banco/configuracao e executar testes de rotas e certificados.

6.3 F-03 - Exposicao excessiva de portas

Severidade: Alta

Evidencia. As portas 81, 3000, 8000 e 9443 escutam em todas as interfaces, além das portas esperadas 22, 80 e 443.

Impacto. Qualquer dispositivo na rede local, e possivelmente regras de encaminhamento do roteador, pode alcançar interfaces administrativas ou contornar o proxy.

Recomendacao. Remover a publicacao direta da porta 3000, restringir administracao a localhost, VPN, Cloudflare Access ou sub-rede administrativa, remover 8000 se o Edge Agent nao for usado e adotar firewall default-deny.

6.4 F-04 - Privilegios equivalentes a root

Severidade: Alta

Evidencia. Portainer monta /var/run/docker.sock com leitura e escrita; o usuario leandro pertence ao grupo docker. Portainer, NPM e Evolution executam como root no container.

Impacto. Acesso ao socket ou ao grupo docker permite controle amplo do host. Uma conta administrativa comprometida pode criar containers privilegiados, montar o sistema de arquivos e extrair segredos.

Recomendacao. Minimizar administradores, proteger Portainer com MFA/controle de acesso, avaliar socket-proxy com permissoes minimas, separar usuario de deploy e revisar a necessidade de root em cada container.

6.5 F-05 - Segredos em variaveis de ambiente

Severidade: Alta

Evidencia. Foram identificadas categorias sensiveis como service role do Supabase, segredos Stripe, chave Evolution, chave OpenAI, senha Redis, chave de criptografia, pepper de PIN, segredos PixGo e segredo de cron. Nenhum valor foi registrado.

Impacto. Administradores Docker/Portainer e processos com acesso equivalente ao daemon podem inspecionar esses valores.

Recomendacao. Migrar segredos de maior impacto para Docker Compose secrets ou cofre criptografado, limitar Portainer e definir procedimento de rotacao. Rotacionar imediatamente se houver suspeita de exposicao.

6.6 F-06 - DNS antigo e certificados falhando

Severidade: Alta operacional

Evidencia. Dominios roboajuda.site ainda resolvem para 2.57.91.92, enquanto rotas antigas permanecem no NPM. As renovacoes Let's Encrypt falham repetidamente porque o desafio ACME chega ao endereco antigo.

Impacto. Alertas recorrentes, certificados proximos do vencimento e risco de trafego ou credenciais serem direcionados a infraestrutura fora do controle atual.

Recomendacao. Confirmar a titularidade de 2.57.91.92. Se nao pertencer mais ao responsavel, remover ou corrigir DNS imediatamente, desativar proxies obsoletos e revogar/remover certificados sem uso.

6.7 F-07 - Hardening do SSH

Severidade: Media/alta

Evidencia. O handshake anuncia publickey e password; X11Forwarding esta habilitado e fail2ban nao foi encontrado. KbdInteractiveAuthentication esta desabilitado.

Impacto. Aumento da superficie para forza bruta, uso indevido de senha e recursos desnecessarios.

Recomendacao. Depois de validar duas sessoes por chave, desabilitar senha e root, desabilitar X11, limitar usuarios e tentativas. Restringir a chave de automacao por origem e opcoes de authorized_keys.

6.8 F-08 - Ausencia de healthchecks e limites

Severidade: Media

Evidencia. Nenhum container possui healthcheck. Nao ha limites de memoria, CPU ou PIDs. O worker consumia aproximadamente 667 MiB, cerca de 18% da RAM.

Impacto. Um processo travado pode continuar marcado como ativo; crescimento descontrolado pode pressionar memoria e afetar todos os servicos.

Recomendacao. Adicionar healthchecks adequados, heartbeat de worker/scheduler e limites graduais baseados em medicoes, com alertas antes de reinicios automaticos.

6.9 F-09 - Logs sem rotacao

Severidade: Media

Evidencia. O driver json-file esta em uso sem max-size e max-file configurados.

Impacto. Crescimento indefinido dos logs pode ocupar o disco e causar indisponibilidade.

Recomendacao. Configurar rotacao, por exemplo max-size 10m e max-file entre 3 e 5, validando necessidades de retencao e suporte.

6.10 F-10 - Ajuste de memoria do Redis

Severidade: Media

Evidencia. O Redis alerta que vm.overcommit_memory esta desabilitado; o host reporta valor 0.

Impacto. Operacoes de fork, persistencia ou baixa memoria podem falhar em cenarios de pressao.

Recomendacao. Definir vm.overcommit_memory=1 de forma persistente em janela controlada e validar o alerta apos a alteracao.

6.11 F-11 - Atualizacoes e ciclo de vida

Severidade: Media

Evidencia. Debian 12 entrou em LTS; unattended-upgrades não está instalado. Docker 29.5.2 estava atrás do ramo 29.6.2 e cloudflared 2026.7.2 informava patch 2026.7.3.

Impacto. Atraso acumulado aumenta exposição e torna futuras atualizações mais arriscadas.

Recomendação. Definir calendário de manutenção, atualizar por criticidade, fixar imagens por versão ou digest e planejar migração para Debian 13 em 30 a 90 dias, com teste de drivers e rollback.

6.12 F-12 - Endurecimento HTTP adicional

Severidade: Baixa

Evidencia. A CSP permite unsafe-inline para scripts e estilos, e o cabeçalho X-Powered-By revela Next.js.

Impacto. Esses itens ajudam reconhecimento e reduzem a resistência da CSP, embora os demais cabeçalhos estejam bem configurados.

Recomendação. Remover X-Powered-By e evoluir a CSP para nonce/hash quando compatível com a aplicação, sem quebrar funcionalidades.

7. Evidências operacionais relevantes

7.1 Estado do erro 502

O erro anterior 'upstream sent too big header while reading response header from upstream' teve último registro em 29/07/2026 às 12:04. Não foram encontrados novos eventos depois do aumento dos buffers do proxy.

Resultado: a correção de buffers foi bem-sucedida nas evidências observadas. O problema deve continuar monitorado por pelo menos sete dias.

7.2 Logs e disponibilidade

42. Aplicação respondeu HTTP 200 em aproximadamente 9 ms no teste local.
43. Nginx Proxy Manager respondeu HTTP 200 em aproximadamente 15 ms.
44. Não foram encontrados padrões de erro nos logs principais da aplicação nas últimas 24 horas.
45. Houve um erro transitório de stream WhatsApp com código 503 na Evolution.
46. Duas mensagens 'role root does not exist' no PostgreSQL foram produzidas pelo comando de auditoria pg_isready sem usuário explícito, não por falha da aplicação.
47. As falhas mais numerosas do NPM eram renovações ACME repetidas dos domínios antigos.

7.3 DNS e tunel

Nome	Destino/estado
------	----------------

Nome	Destino/estado
lembrado.com.br e www	Cloudflare; site funcional pelo Tunnel.
Origem do Tunnel	http://192.168.1.11:80.
api.robajuda.site	2.57.91.92; configuracao antiga.
queue.robajuda.site	2.57.91.92; configuracao antiga.
portainer.robajuda.site	2.57.91.92; configuracao antiga.
proxy.robajuda.site	2.57.91.92; configuracao antiga.
robajuda.site	2.57.91.92; configuracao antiga.

A aplicacao usa `EVOLUTION_API_URL` interno, apontando para o servico Docker `evolution-api:8080`. Portanto, nas configuracoes observadas, a chave `Evolution` nao e enviada ao IP antigo.

8. Plano de remediacao recomendado

Regra de mudanca: cada fase deve ter backup, criterio de aceite, rollback documentado e janela de manutencao. Alteracoes de rede devem preservar uma sessao SSH de contingencia ate a validacao final.

Fase 0 - Recuperacao antes de qualquer mudanca

48. Exportar as stacks e arquivos Compose do Portainer.
49. Executar `pg_dump` consistente do PostgreSQL da Evolution.
50. Copiar o volume de instancias/sesoes da Evolution com o servico em estado consistente.
51. Salvar `nginx_npm_data`, `nginx_npm_letsencrypt` e `portainer_data`.
52. Manter copia criptografada fora do host, com retencao definida.
53. Restaurar em ambiente temporario isolado e registrar evidencias do teste.

Criterio de aceite: Backup concluido, hash/manifesto registrado e restauracao funcional comprovada.

Fase 1 - DNS e certificados antigos

54. Confirmar quem controla 2.57.91.92.
55. Inventariar dependencias ainda ativas de robajuda.site.
56. Corrigir ou remover DNS antigo, proxies e certificados sem uso.
57. Confirmar que as renovacoes ACME deixam de falhar.

Criterio de aceite: Nenhum dominio controlado aponta para infraestrutura indevida; logs ACME limpos.

Fase 2 - Atualizacao do proxy

- 58. Fixar Nginx Proxy Manager em versao 2.15.0 ou superior validada.
- 59. Registrar imagem anterior e procedimento de rollback.
- 60. Atualizar em janela; testar login, rotas, certificados e cabecalhos.

Criterio de aceite: Site, APIs e painel respondem; certificados validos; sem regressao de 502.

Fase 3 - Reducao da superficie de rede

- 61. Remover publicacao direta da aplicacao na porta 3000 quando o NPM compartilhar a rede Docker.
- 62. Restringir 81 e 9443 a origem administrativa segura.
- 63. Remover 8000 se Edge Agent nao estiver em uso.
- 64. Revisar encaminhamentos do roteador e implantar firewall default-deny.
- 65. Considerar cloudflared conectado diretamente a rede Docker e ao nome do servico.

Criterio de aceite: Somente portas justificadas permanecem acessiveis; administracao funciona apenas pelo caminho autorizado.

Fase 4 - SSH e privilegios

- 66. Validar login por chave em duas sessoes antes de desabilitar senha.
- 67. Definir PasswordAuthentication no, PermitRootLogin no e X11Forwarding no.
- 68. Aplicar AllowUsers e MaxAuthTries restritivos.
- 69. Restringir chave de automacao por origem e opcoes restrict.
- 70. Revisar membros do grupo docker e administradores do Portainer.

Criterio de aceite: Login administrativo por chave funciona; senha/root/X11 bloqueados; sem perda de acesso.

Fase 5 - Segredos

- 71. Classificar segredos por impacto e dependencia.
- 72. Migrar os mais criticos para secrets/cofre criptografado.
- 73. Limitar quem pode inspecionar containers.
- 74. Rotacionar segredos com procedimento coordenado e teste de rollback.

Criterio de aceite: Valores não aparecem em configurações acessíveis além do necessário; aplicação e webhooks continuam válidos.

Fase 6 - Resiliência e observabilidade

- 75. Definir `vm.overcommit_memory=1`.
- 76. Adicionar healthchecks e heartbeat para jobs.
- 77. Aplicar limites de memória, CPU e PIDs gradualmente.
- 78. Configurar rotação de logs Docker.
- 79. Alertar falhas de backup, expiração de certificados, disco, memória e containers.

Criterio de aceite: Alertas testados, healthchecks confiáveis, logs limitados e recursos sem regressão.

Fase 7 - Atualizações e ciclo contínuo

- 80. Atualizar CloudFlare e Docker em janelas separadas.
- 81. Adotar unattended-upgrades ou calendário formal de patches.
- 82. Planejar Debian 13 com teste de compatibilidade e rollback.
- 83. Substituir latest por versões ou digests controlados.
- 84. Executar teste de restauração recorrente e revisão trimestral.

Criterio de aceite: Inventário versionado, rotina documentada e evidências periódicas de recuperação.

9. Checklist de backup e restauração

Controle	Condição mínima
Inventário	Volumes, stacks, imagens, versões e dependências documentados.
PostgreSQL Evolution	Dump lógico validado e restaurado em instância isolada.
Sessões Evolution	Volume copiado em estado consistente; permissões preservadas.
NPM	Dados, certificados e banco/configuração recuperáveis.
Portainer	<code>portainer_data</code> e arquivos Compose exportados fora do volume.
Redis	Decidir se estado precisa de backup; validar AOF/RDB conforme uso.
Segredos	Backup criptografado; acesso e chave de recuperação separados.
Cópia externa	Destino fora do host; criptografia; retenção e imutabilidade quando possível.
Teste	Restauração executada, tempo medido e evidências salvas.
Monitoramento	Falha, atraso ou tamanho anormal do backup gera alerta.

10. Critérios de validação final

- 85. Backup externo existe, pode ser lido e foi restaurado em ambiente isolado.
- 86. Site lembrado.com.br, login, painel, renovacoes, PIX, WhatsApp e jobs criticos passam por smoke test.
- 87. Nenhum novo 502 ou 'too big header' aparece durante a janela de observacao.
- 88. Administracao NPM/Portainer nao e acessivel de redes nao autorizadas.
- 89. Porta 3000 nao contorna o proxy; portas 8000/9443/81 seguem a politica definida.
- 90. SSH por chave funciona e autenticao por senha/root esta bloqueada.
- 91. NPM esta atualizado e com rollback conhecido.
- 92. Renovacoes ACME funcionam ou configuracoes antigas foram removidas.
- 93. Healthchecks refletem o estado real; alertas e rotacao de logs foram testados.
- 94. Segredos permanecem funcionais, nao foram registrados em logs e possuem responsavel de rotacao.

11. Fontes tecnicas

Docker - privilegios do grupo docker: <https://docs.docker.com/engine/install/linux-postinstall/>

Docker - seguranca do daemon: <https://docs.docker.com/engine/security/>

Docker - rotacao do driver json-file: <https://docs.docker.com/engine/logging/drivers/json-file/>

Cloudflare - conectividade por Tunnel: <https://developers.cloudflare.com/cloudflare-one/networks/connectivity-options/>

Nginx Proxy Manager - releases: <https://github.com/NginxProxyManager/nginx-proxy-manager/releases>

Portainer - releases: <https://github.com/portainer/portainer/releases>

Evolution API - releases: <https://github.com/evolution-foundation/evolution-api/releases>

Docker Engine 29 - notas de versao: <https://docs.docker.com/engine/release-notes/29/>

Debian 12 LTS: <https://www.debian.org/News/2026/20260712>

Debian - sshd_config: https://manpages.debian.org/bookworm/openssh-server/sshd_config.5.en.html

12. Observacao de confidencialidade

Este relatorio contem enderecos de rede, nomes de servicos e arquitetura suficientes para orientar manutencao. Deve ser compartilhado somente com pessoas autorizadas. O documento foi deliberadamente produzido sem senhas, tokens, chaves, valores de variaveis de ambiente, fingerprints, IDs de maquina ou dados de historico de acesso.

Estado da auditoria: levantamento concluido sem alteracoes no homelab. A implementacao deve seguir a ordem do plano e exigir aprovacao explicita para cada mudanca com impacto.